IT-Notfallhandbuch & BCM-Richtlinie

Dokumenten-ID: POL-BCM-01 | Version: 2.1 | Freigabe: CISO-Office | Vertraulichkeit: Intern

§ 1 Zweck und Geltungsbereich

Diese Richtlinie definiert die organisatorischen und technischen Maßnahmen zur Aufrechterhaltung und Wiederherstellung des Geschäftsbetriebs (Business Continuity Management, BCM) im Falle eines IT-Notfalls oder einer Krise. Sie gilt bindend für alle Mitarbeitenden, externen Dienstleister und Führungskräfte, die Zugriff auf die IT-Infrastruktur des Unternehmens haben. Ein IT-Notfall liegt vor, wenn kritische Geschäftsprozesse durch den Ausfall von IT-Systemen, Cyberangriffe (wie Ransomware) oder elementare Schäden am Rechenzentrum massiv beeinträchtigt werden und die Störung nicht innerhalb der regulären Service-Level-Agreements (SLA) behoben werden kann.

§ 2 Eskalationsstufen und Krisenstab

Störungen werden anhand ihrer Auswirkungen auf die Geschäftsprozesse klassifiziert. Eine sofortige Eskalation an das CISO-Office und die Einberufung des IT-Krisenstabs erfolgt zwingend bei Vorfällen der Stufe 3 und 4.

- **Stufe 1 (Normaler Vorfall):** Lokale Störung einzelner Arbeitsplätze. Bearbeitung erfolgt über den regulären 1st-Level-Support (Service Desk).
- **Stufe 2 (Schwerer Vorfall):** Ausfall von Systemen der Tier-3-Kategorie. Eskalation an den diensthabenden IT-Leiter. Behebung innerhalb von 8 Stunden.
- **Stufe 3 (Notfall):** Ausfall von kritischen Systemen (Tier 1 oder Tier 2) oder konkreter Verdacht auf einen Cyberangriff mit Datenabfluss. Der IT-Krisenstab wird unverzüglich alarmiert.
- **Stufe 4 (Krise):** Unternehmensweite Nichtverfügbarkeit der Kernsysteme (z.B. flächendeckende Ransomware-Verschlüsselung) oder existenzbedrohender Reputationsverlust. Die Geschäftsführung übernimmt die Leitung des Krisenstabs.

Wichtiger Hinweis zur Alarmierung: Außerhalb der regulären Geschäftszeiten (20:00 bis 06:00 Uhr) ist bei einem Notfall der Stufe 3 oder 4 zwingend die 24/7-Notfall-Hotline des externen SOC (Security Operations Center) unter der Rufnummer +43 1 234 5678 anzurufen.

§ 3 Wiederanlaufzeiten (RTO und RPO)

Für alle IT-Services wurden in der Business Impact Analyse (BIA) verbindliche Vorgaben für die maximale Ausfallzeit (Recovery Time Objective, RTO) und den maximal zulässigen Datenverlust (Recovery Point Objective, RPO) definiert. Diese Vorgaben sind bei der Architektur-Planung zwingend umzusetzen.

Kritikalität	Beispiel-Systeme	RTO (Ausfallzeit)	RPO (Datenverlust)
Tier 1 (Kritisch)	Active Directory, ERP-Kernsystem, zentrale Firewalls, Produktionssteuerung	4 Stunden	15 Minuten
Tier 2 (Hoch)	E-Mail-Server, interne Dateiserver, HR-Systeme, Ticketsystem	12 Stunden	1 Stunde
Tier 3 (Mittel)	Intranet (lesend), Archivsysteme, Entwicklungs-Umgebungen	48 Stunden	24 Stunden
Tier 4 (Gering)	Testsysteme, Altdaten-Repositories, temporäre Fileshares	5 Werktage	7 Tage

§ 4 Meldewege und NIS-2-Compliance

Zur Erfüllung der gesetzlichen Meldepflichten nach dem NIS-2-Umsetzungsgesetz (NIS-2-UmsG) gelten für sicherheitsrelevante Vorfälle strikte Fristen. Jeder Vorfall, der potenziell die Verfügbarkeit, Authentizität, Integrität oder Vertraulichkeit von Daten gefährdet, muss sofort an das CISO-Office gemeldet werden.

Das CISO-Office bewertet den Vorfall. Handelt es sich um einen „erheblichen Sicherheitsvorfall“ im Sinne des Gesetzes, ist das CISO-Office verpflichtet, innerhalb von **24 Stunden** eine Erstmeldung (Frühwarnung) an das Bundesamt für Sicherheit in der Informationstechnik (BSI) bzw. das nationale CSIRT abzugeben. Eine detaillierte Vorfallmeldung hat zwingend innerhalb von **72 Stunden** nach Kenntniserlangung zu erfolgen. Die eigenmächtige Kommunikation mit Behörden durch IT-Administratoren oder Fachbereiche ist strengstens untersagt.